Segregation of Duties Risk Report

Accounts payable access review, Salesforce lab org

Prepared by	Milad Jafarieh
Review date	October 25, 2026
System	Salesforce Developer Edition org built for this lab (test users only, no real data)
Process	Accounts payable: vendors, invoices and payments
Tools	analyze.py and remediate.py in github.com/Meelaad/access-governance-lab
Version	1.0

1. Summary

This review checked who can do what in the accounts payable part of a Salesforce org. Every user's effective access was compared against 6 segregation of duties (SoD) rules and a role access policy, and the conflicts were removed and checked again.

- **First run:** 10 SoD conflicts across 7 users, 4 of them Critical or High, and 13 other access findings.
- **After the fix:** 4 SoD conflicts across 2 users, none Critical or High, and 6 other findings. Everything left is on the two System Administrator accounts or Salesforce's own integration user.
- **Most serious finding:** an AP manager who could change a vendor's bank account and approve the payment to it. That access has been removed.
- **Still open:** administrators can switch off the payment approval control, and every user on the standard profiles can export reports. Both need more than removing a permission set (F-03 and F-08).

2. Scope

In scope:

- **Users:** all 10 standard users in the org: 6 AP, IT and sales test users, the admin account (tek), a second admin created with the org (OEPIC) and two built-in Salesforce analytics users (integ, sec).
- **Objects:** Vendor__c (with Bank_Account__c), Invoice__c and Payment__c (with Approved__c). Read, create, edit and delete on the objects and edit on their fields.
- **Permissions:** Modify All Data, View All Data, Manage Users, Assign Permission Sets, Author Apex, Customize Application and Export Reports, plus the Approve Payments custom permission.
- **Sources of access:** profiles, permission sets and permission set groups.

Out of scope:

- Record sharing (org-wide defaults, role hierarchy, sharing rules). The review looks at what a user can do to a type of record, not which records they can see.
- Apex code, flows and integrations that run in system mode.
- Login security such as MFA, IP ranges and session settings.

3. Method

1. **Collect.** The analyzer pulls every permission set assignment with the Salesforce CLI. A profile is stored as a permission set too, so profile access is included and nothing is missed.

2. **Combine.** A user's access is everything from their profile, permission sets and groups added together. Each permission keeps a note of where it came from, so a finding says which assignment to remove.
3. **Check SoD.** An SoD rule has two sides, and each side lists one or more permissions. A user breaks the rule when they hold at least one permission from each side.
4. **Check the policy.** The role policy lists which permission sets each role may have. Anything else is access outside the policy. The analyzer also flags privileged system permissions, inactive users who still have permission sets and users with no role in the policy.
5. **Check the roles.** Each role's allowed access is also checked against the SoD rules, so a role that breaks a rule by design is caught. No role did.
6. **Fix and verify.** Changes were listed in reports/remediation-plan.csv, applied with remediate.py and checked by running the analyzer again. The results of both runs are kept in reports/first-run and reports/after-fix.

4. Risk rating

Each finding is rated by how likely the access is to be misused and how bad it would be if it were. Likelihood looks at whether one person can act alone, whether the account can log in, and whether another control would catch it. Impact looks at money lost and data exposed.

Impact \ Likelihood	Low	Medium	High
High	Medium	High	Critical
Medium	Low	Medium	High
Low	Low	Low	Medium

5. SoD rules

The rules come from the accounts payable process: setting up a vendor, entering an invoice and approving the payment should need at least two people. The rule risk is the worst case. A finding can be rated lower, for example when the user can't log in.

ID	Conflict	Rule risk	Why it matters
SOD-01	Change vendors and approve payments	High	Someone could set up or change a vendor and then approve paying it.
SOD-02	Change vendor bank details and approve payments	Critical	Someone could point a real vendor's payments to their own bank account and approve the payment.
SOD-03	Enter invoices and approve payments	High	Someone could enter a fake invoice and approve paying it.
SOD-04	Create vendors and enter invoices	Medium	Someone could create a fake vendor and enter invoices from it. A separate approver still has to approve the payment.
SOD-05	Manage access and approve payments	High	Someone who can hand out access could give themselves any AP duty, and they can already approve payments.
SOD-06	View all data and export reports	Medium	Someone could read every record in the org and take it out in a report export.

6. Findings

ID	Finding	Users	Rating	Status
F-01	AP manager could change vendor bank details and approve payments	jpatel	Critical	Fixed and verified

F-02	IT support could hand out access and approve payments	tbrooks	High	Fixed and verified
F-03	System administrators can get around the payment approval control	tek, OEPIC	High	Accepted (tek)
F-04	Unused second System Administrator account	OEPIC	High	Fixed and verified (frozen)
F-05	Leaver kept invoice entry and payment approval	cnguyen	Medium	Fixed and verified
F-06	AP clerk could create vendors and enter invoices	achen	Medium	Fixed and verified
F-07	Sales analyst could view all data and export it	mlee	Medium	Fixed and verified
F-08	Every user on the standard profiles can export reports	all users on Standard User and Standard Platform User	Medium	Open, target November 30, 2026
F-09	Analytics integration user has View All Data	integ	Low	Accepted
F-10	Admin account has permission sets it didn't ask for	tek	Low	Open

F-01 AP manager could change vendor bank details and approve payments

Rating: Critical (likelihood high, impact high)

Users: jpatel

What was found: Breaks SOD-02 and SOD-01. AP_Vendor_Maintenance was assigned on top of AP_Payment_Approval, which the AP_Manager role doesn't allow. This user could change a real vendor's bank account to their own and approve the payment alone.

Fix: Removed AP_Vendor_Maintenance. Vendor bank details now sit only with the Vendor_Data role.

Owner and status: AP process owner (Finance). Fixed and verified.

Residual risk: Low. Field history tracks every change to the bank account and the approval flag.

F-02 IT support could hand out access and approve payments

Rating: High (likelihood medium, impact high)

Users: tbrooks

What was found: Breaks SOD-05. AP_Payment_Approval was assigned to an IT_Support user who also has User_Admin (Manage Users, Assign Permission Sets).

Fix: Removed AP_Payment_Approval.

Owner and status: IT security and Salesforce admin. Fixed and verified.

Residual risk: Medium. User_Admin can still assign any permission set, including AP_Payment_Approval, to anyone, even themselves. Removing the set closes the conflict today but not the path back to it (recommendation 2).

F-03 System administrators can get around the payment approval control

Rating: High (likelihood medium, impact high)

Users: tek, OEPIC

What was found: The analyzer flags both admins for SOD-04 and SOD-06 only, because they don't hold the Approve Payments custom permission. But Customize Application lets them switch off the validation rule that checks it, and Assign Permission Sets lets them give themselves AP_Payment_Approval. In practice an admin holds both sides of every rule.

Fix: tek is the only working admin account, so it was accepted with checks: field history on the bank account and approval fields and the Setup Audit Trail, which records validation rule and permission set changes. OEPIC is covered by F-04.

Owner and status: IT security. Accepted (tek).

Residual risk: Medium. The checks only work if someone other than the admin reviews them (recommendation 3).

F-04 Unused second System Administrator account

Rating: High (likelihood medium, impact high)

Users: OEPIC

What was found: A second System Administrator was created along with the Developer Edition org. Nobody uses it, but it had full access, including Modify All Data. A dormant admin account is an easy target because nobody notices if it starts logging in.

Fix: Frozen, so it can't log in. It was frozen rather than deactivated in case the org needs it.

Owner and status: Salesforce admin. Fixed and verified (frozen).

Residual risk: Low. Deactivate it once it's confirmed nothing depends on it.

F-05 Leaver kept invoice entry and payment approval

Rating: Medium (likelihood low, impact high)

Users: cnguyen

What was found: Breaks SOD-03 (High). The user left and was deactivated, but their permission sets were never removed, and AP_Payment_Approval was outside the AP_Clerk role anyway. Rated Medium because an inactive user can't log in. Reactivating the account would bring all of the access back.

Fix: Removed AP_Invoice_Entry and AP_Payment_Approval.

Owner and status: HR and Salesforce admin (offboarding). Fixed and verified.

Residual risk: Low. The offboarding step that missed this is still a gap (recommendation 5).

F-06 AP clerk could create vendors and enter invoices

Rating: Medium (likelihood medium, impact medium)

Users: achen

What was found: Breaks SOD-04. AP_Vendor_Maintenance was assigned on top of AP_Invoice_Entry. The clerk could create a fake vendor and enter invoices from it, but a separate approver still has to approve the payment.

Fix: Removed AP_Vendor_Maintenance.

Owner and status: AP process owner (Finance). Fixed and verified.

Residual risk: Low.

F-07 Sales analyst could view all data and export it

Rating: Medium (likelihood medium, impact medium)

Users: mlee

What was found: Breaks SOD-06. View_All_Data is not part of the Sales_Analyst role. With Export Reports this user could read every record in the org, including vendor bank accounts, and take it out in a report export.

Fix: Removed View_All_Data.

Owner and status: Sales operations manager. Fixed and verified.

Residual risk: Low. The user can still export, but only the records they can see.

F-08 Every user on the standard profiles can export reports

Rating: Medium (likelihood medium, impact medium)

Users: all users on Standard User and Standard Platform User

What was found: Export Reports comes from the Standard User and Standard Platform User profiles, so every non-admin user has it. The Report_Export permission set the policy allows only for Sales_Analyst makes no difference, because Salesforce permissions only add up and a permission set can't take one away. Standard profiles can't be edited.

Fix: Not fixed yet. Clone the two profiles into custom profiles without Export Reports, move the users and keep Report_Export as the only way to get it.

Owner and status: Salesforce admin. Open, target November 30, 2026.

Residual risk: Medium until the profiles are changed.

F-09 Analytics integration user has View All Data

Rating: Low (likelihood low, impact medium)

Users: integ

What was found: Salesforce's built-in CRM Analytics integration user gets View All Data from its locked profile. It can't log in like a person.

Fix: No change. Its profile can't be edited.

Owner and status: Salesforce admin. Accepted.

Residual risk: Low. Don't assign it any extra permission sets.

F-10 Admin account has permission sets it didn't ask for

Rating: Low (likelihood low, impact low)

Users: tek

What was found: The admin account came with 5 permission sets for AI and agent features (for example GenieAdmin and CopilotSalesforceAdmin). None are in the role policy. The admin already has full access from its profile, so they add little risk, but each one should have a reason to be there.

Fix: Review them and remove the ones that aren't used.

Owner and status: Salesforce admin. Open.

Residual risk: Low.

7. Before and after

The analyzer was run again after the changes in section 8. Every Critical and High conflict is gone, and so is all access outside the role policy.

	First run	After fix
SoD conflicts	10 across 7 users	4 across 2 users
Critical	1	0
High	3	0
Medium	6	4
Other access findings	13	6
Access outside the role policy	5	0
Inactive users with access	1	0
Users with privileged access	5	4
Roles that break a rule by design	0	0

The 4 conflicts left are SOD-04 and SOD-06 on tek (accepted, F-03) and OEPIC (frozen, F-04). Privileged access is left on the two admins, integ (F-09) and tbrooks, whose Manage Users permission is what the IT_Support role is for.

8. Changes made

Applied on October 25, 2026 with python remediate.py --apply. The script only prints what it would do unless --apply is given, and running it a second time changes nothing.

User	Change	Permission set	Reason
achen	Removed	AP_Vendor_Maintenance	Not part of the AP Clerk role. Breaks SOD-04.
jpatel	Removed	AP_Vendor_Maintenance	Not part of the AP Manager role. Breaks SOD-01 and SOD-02.
cnguyen	Removed	AP_Invoice_Entry	Left the company.
cnguyen	Removed	AP_Payment_Approval	Left the company. Breaks SOD-03.
tbrooks	Removed	AP_Payment_Approval	Not part of the IT Support role. Breaks SOD-05.
mlee	Removed	View_All_Data	Not part of the Sales Analyst role. Breaks SOD-06.
OEPIC	Frozen		Second System Administrator that came with the org. Nobody uses it, so it gets frozen.
tek	Accepted		My own admin account. An org needs one admin, so this stays, with field history on bank account and approvals and the setup audit trail as checks.
integ	Accepted		Salesforce's built-in analytics integration user. It can't log in like a person and View All Data comes from its locked profile.

9. Recommendations

1. **Custom profiles.** Replace the Standard User and Standard Platform User profiles with custom copies that don't have Export Reports, so Report_Export is the only way to get it (F-08).
2. **Control AP access grants.** Limit who can assign AP_Payment_Approval. Options are delegated administration that only covers non-AP permission sets, or a second approver for AP access requests. Review permission set assignments in the Setup Audit Trail every month (F-02).
3. **Watch the admins.** Use a separate admin account for setup work and have someone outside IT review Setup Audit Trail changes to the approval validation rule and the AP permission sets (F-03).
4. **Remove the dormant admin.** Deactivate OEPIC once it's confirmed nothing needs it (F-04).
5. **Fix offboarding.** Remove permission sets as part of offboarding, before the user is deactivated, and check for inactive users with access every month (F-05).
6. **Make it routine.** Run the analyzer after every access change and as part of a quarterly access review, with each manager signing off on their team's access.
7. **Extend the analyzer.** Add a rule for users who can get around controls (Customize Application or Assign Permission Sets together with any AP duty), so admins show up for every rule they could break (F-03).

10. Limitations

- This is a lab org with test users. Five of the six test users were given extra access on purpose to test the analyzer (achen, jpatel, cnguyen, tbrooks and mlee). The findings about the admins, the standard profiles and the integration user were not planted. They came with the org.

- The analyzer only sees permissions. A user without a permission can't do the action, but having one doesn't mean they've used it. Field history and the audit trail would show that.
- Record sharing, Apex and flows running in system mode, and login settings were not reviewed.

Appendix A. Role-to-permission matrix

What each role is allowed through the role policy, after the fix. Only permissions that at least one role has are shown. The full user and role matrices are in reports/after-fix.

Permission	AP_Clerk	AP_Manager	Vendor_Data	IT_Support	Sales_Analyst
Invoice__c.Amount__c:edit	x				
Invoice__c.Vendor__c:edit	x				
Invoice__c:create	x				
Invoice__c:edit	x				
Invoice__c:read	x	x			
Payment__c.Approved__c:edit		x			
Payment__c:edit		x			
Payment__c:read		x			
Vendor__c.Bank_Account__c:edit			x		
Vendor__c:create			x		
Vendor__c:edit			x		
Vendor__c:read	x	x	x		
custom:Approve_Payments		x			
perm:AssignPermissionSets				x	
perm:ExportReport					x
perm:ManageUsers				x	

Appendix B. How to run it again

```
python setup_lab.py
python analyze.py --out reports/first-run
python remediate.py
python remediate.py --apply
python analyze.py --out reports/after-fix
```